

API SECURITY RISK ANALYSIS REPORT

MAY 2026

Mukesh Chegondi

Introduction

This report analyzes the security posture of a public API using browser developer tools and Postman. The objective is to identify authentication weaknesses, data exposure risks, missing security controls, and improper API configurations.

OBJECTIVES

- This report analyzes the security posture of a public API using browser developer tools and Postman.
- The objective is to identify authentication weaknesses, data exposure risks, missing security controls, and improper API configurations.

SCOPE

Included:

- Public API endpoint testing
- Header analysis
- Authentication analysis
- Response inspection

Excluded:

- Exploitation
- DoS attacks
- Unauthorized access attempts

Tools Used

- Postman
- Google Chrome DevTools
- JSONPlaceholder API
- Browser Network Analyzer
- GitHub

Target API

API USED

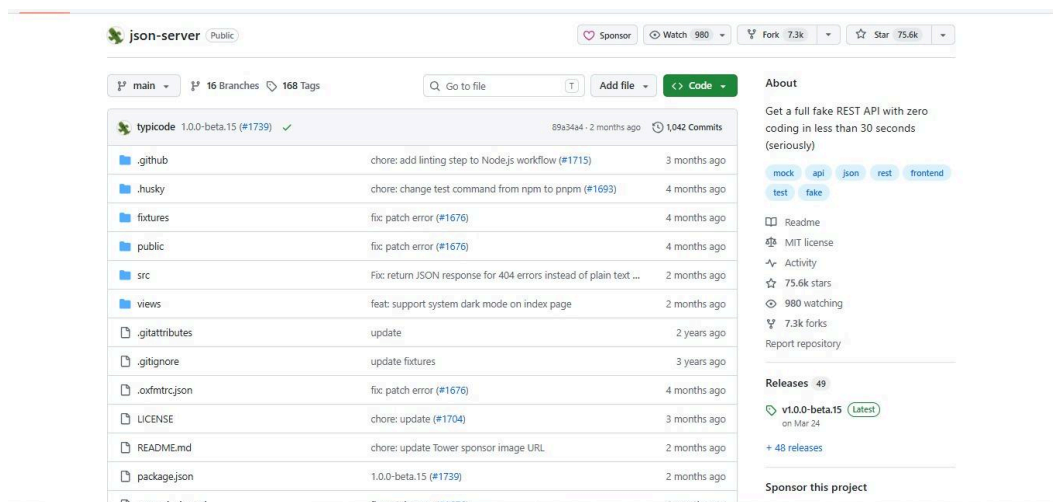
<https://jsonplaceholder.typicode.com/posts>

Purpose: A public REST API used for testing and learning API requests.

Methodology

Step 1 — API Selection

Selected JSONPlaceholder public API for testing.



Step 2 : Browser Traffic Analysis

Opened Chrome DevTools → Network Tab to inspect API requests.

Observed:

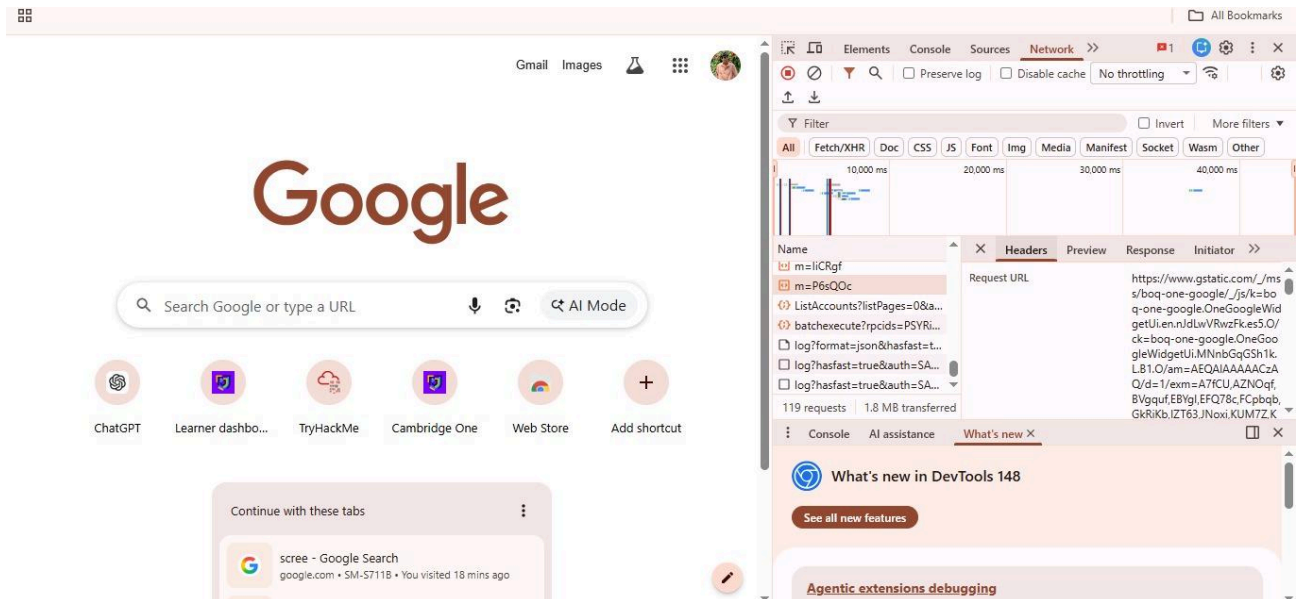
Request URL

Response headers

Status codes

Response size

Request timing



Step 3 — API Testing in Postman

Sent GET request to:

Http

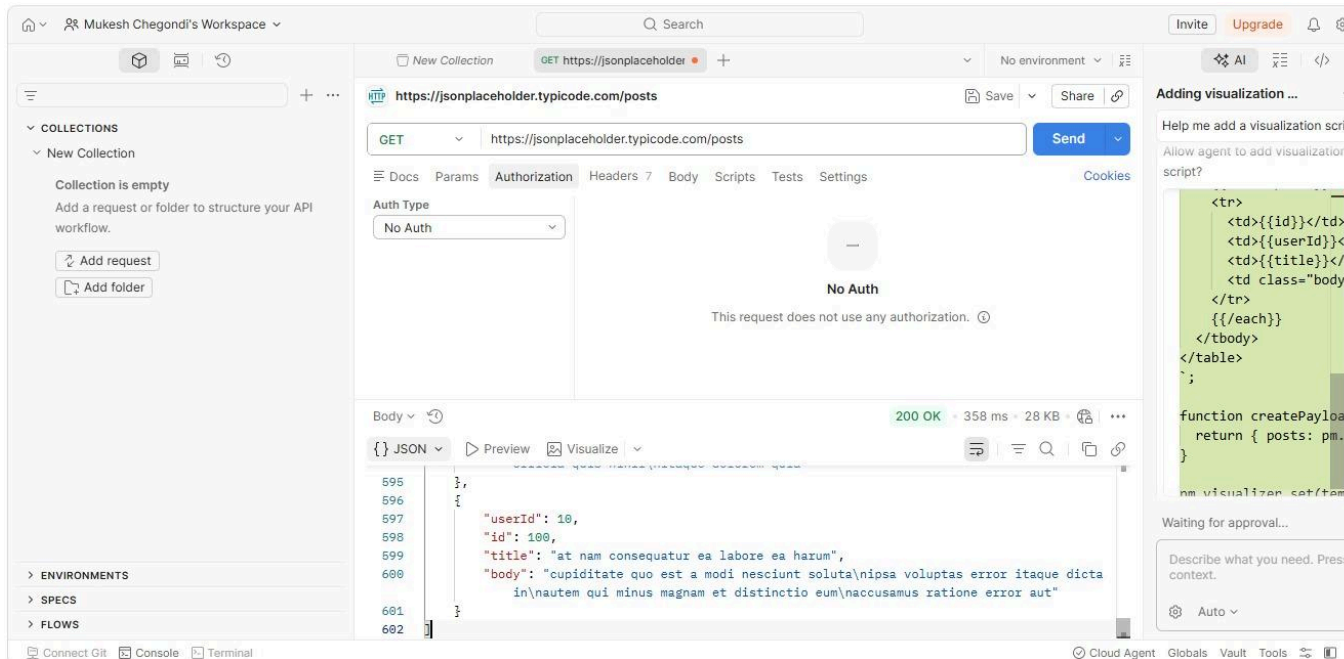
GET /posts

Observed:

HTTP Status: 200 OK

JSON response data returned successfully

No authentication required.

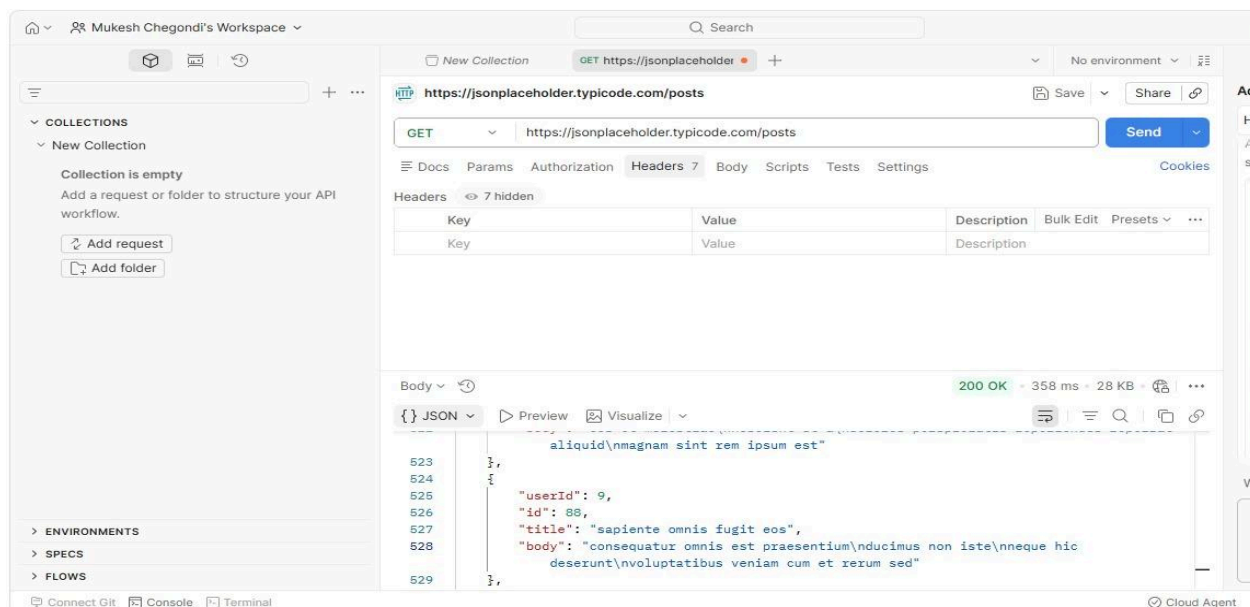


Step 4 — Header Inspection

- Inspected API headers inside Postman.

Findings:

- Missing Authorization token
- No rate limiting headers
- Publicly accessible endpoint



Risk	Severity	Description
No Authentication	Medium	API allows unrestricted access
Missing Rate Limiting	Medium	Could enable abuse or API flooding
Public Data Exposure	Low	Data accessible
Public Data Exposure	Low	Data accessible without validation
Public Data Exposure	Low	Data accessible without validation
No Access Control	Medium	Anyone can access endpoint

Risk Analysis

Finding 1 — Missing Authentication

Description

The API endpoint does not require authentication tokens or API keys.

Impact

Attackers may access API resources freely.

Risk Level

 **Medium**

Recommendation

- Implement:
- JWT authentication
- API keys
- OAuth 2.0

Finding 2 — Missing Rate Limiting

Description

- No visible rate-limiting mechanism detected.

Impact

-
- API abuse and denial-of-service risks.

Risk Level

 Medium

Recommendation

Implement:

Request throttling

IP-based limits

CAPTCHA for sensitive actions

8. Indicators Color Classification

Color	Meaning
 Red	High Risk
 Orange	Medium Risk
 Green	Low Risk
 Blue	Informational

Conclusion

The API successfully responded to requests and exposed publicly accessible endpoints. Basic API functionality works correctly; however, security weaknesses such as missing authentication and rate limiting were identified. Implementing stronger access controls and monitoring mechanisms would improve overall API security.